

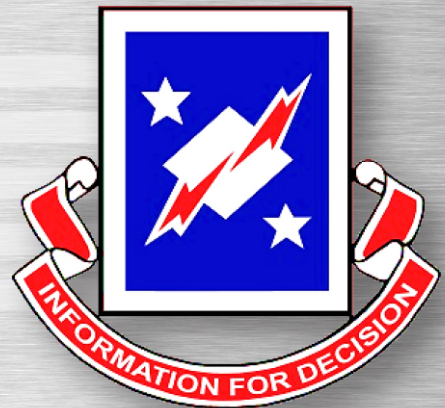
CYBERSECURITY ASSESSMENT AND SECURITY ENGINEERING MANUAL

FEBRUARY 2019

MISSION ENGINEERING DIRECTORATE

Distribution C

Distribution authorized to U.S. Government agencies and their Contractors only, for administrative or operational use, February 2019. Refer other requests for this document to Commander, U.S. Army Information Systems Engineering Command, ATTN: ELIE-ISE-FH, Fort Huachuca, AZ 85613-5300



**U.S. ARMY
INFORMATION SYSTEMS
ENGINEERING COMMAND**

FOR OFFICIAL USE ONLY





DISCLAIMER

The use of trade names in this document does not constitute an official endorsement or approval of the use of such commercial hardware or software. Do not cite this document for advertisement.

CHANGES

Refer requests for all changes that affect this document to: USAISEC, ATTN: ELIE-ISE-ME, Fort Huachuca, AZ 85613-5300.

DISPOSITION INSTRUCTIONS

Destroy this document when no longer needed. Do not return it to the organization. Safeguard and destroy this document with consideration given to its classification or distribution statement requirements.





CYBERSECURITY ASSESSMENT AND SECURITY ENGINEERING MANUAL

FEBRUARY 2019

**MISSION ENGINEERING DIRECTORATE
U.S. ARMY INFORMATION SYSTEMS ENGINEERING COMMAND**

Distribution C

Distribution authorized to U.S. Government agencies and their contractors only, for administrative or operational use, February 2019. Refer other requests for this document to Commander, U.S. Army Information Systems Engineering Command, ATTN: ELIE-ISE-FH, Fort Huachuca, AZ 85613-5300





Table 1. Approvals

Document Approval(s)	Project/Organization Role
Mr. Steven J. Fulbright	Director - Mission Engineering Directorate
Mrs. Deborah D. Harvey	Security Control Assessor - Validator

Table 2. Document Owner(s)

Document Owner(s)	Project/Organization Role
	Cybersecurity Assessment Subject Matter Expert

Table 3. Version Control and Change Log

Version	Date	Author	Change Description
1.0	02 Dec 2013	South, L.	Initial publication date
2.0	30 Aug 2016	Hills, K.	RMF revision publication date
2.1	07 Feb 2019	Harvey, D.	Addition of required certifications





TABLE OF CONTENTS

	Page
1.0 INTRODUCTION.....	1
2.0 HOW THIS MANUAL IS ORGANIZED.....	1
3.0 HOW TO USE THIS MANUAL.....	1
4.0 HOW THIS MANUAL IS UPDATED.....	2
5.0 MISSION.....	2
6.0 CS.....	2
6.1 CS is a Process, not a Discrete Event.....	2
7.0 TERMS AND ACRONYMS.....	3
8.0 REFERENCES.....	3
9.0 SCOPING, PROJECT INITIATION, AND FUNCTIONAL SUPPORT AGREEMENT (FSA) DEVELOPMENT.....	3
10.0 CS SERVICES.....	4
10.1 Matrix Support.....	4
10.2 Initial Scoping.....	4
10.3 Security Assessment (SA).....	4
10.4 Preliminary Assessment.....	5
10.5 Assessment.....	5
11.0 PROCESSES.....	6
11.1 Security Engineering Process.....	6
11.2 Assessment Process.....	6
12.0 TRAINING AND CERTIFICATION.....	7
12.1 IA Training Facility.....	7
12.2 Sustainment Training.....	7
12.3 Certification.....	7
13.0 DATA COLLECTION, ANALYSIS, AND RETENTION.....	7
13.1 Data Collection.....	7
13.2 Protecting Raw Data.....	7
13.3 Collecting and Validating Technical Data.....	8
13.4 Sampling.....	8
13.5 Data Analysis.....	9
13.6 Data Retention.....	9
14.0 TOOLS.....	10
14.1 ISEL - Pronounced I-SELL.....	10
14.2 ISEL WIKI.....	10





Appendices

	Page
APPENDIX A. REFERENCES	A-1
APPENDIX B. SUPPORTING FILES (FILE STRUCTURE)	B-1
APPENDIX C. PROCESSES	C-1
GLOSSARY. ACRONYMS AND ABBREVIATIONS	Glossary-1

Tables

Table 1. Approvals	iv
Table 2. Document Owner(s)	iv
Table 3. Version Control and Change Log	iv
Table 4. Sampling Example	9





CYBERSECURITY ASSESSMENT AND SECURITY ENGINEERING MANUAL

1.0 INTRODUCTION

This manual covers the activities performed during Cybersecurity (CS) Assessment and/or Security Engineering missions. CS professionals assigned to the Mission Engineering Directorate (MED) perform these missions. This manual will refer to MED as The Directorate.

This manual refers to Directorate personnel and includes: 1) all Directorate U.S. Government (USG) civilians, 2) Government Contractors supporting the Directorate, and 3) any other designated representatives conducting or participating in Assessment and/or Security Engineering support.

Processes and procedures are to be followed by all personnel when supporting Assessment and/or Security Engineering missions. Any deviation from the processes and procedures listed herein must be pre-approved by the Director or Group Leader (GL).

While no one party may participate in all processes or procedures, it is vital that the reader understand the complete methodology.

Contractors supporting the Directorate will adhere to all identified Contract Data Requirements List (CDRLs), in addition to the guidance provided in this manual.

This manual does not include those aspects of CS Assessment and Security Engineering that are not directly tied to completing the mission itself, such as budgeting, funds management, personnel matters, etc..

2.0 HOW THIS MANUAL IS ORGANIZED

This manual contains 14 sections and four Appendices. It will guide the reader through the governing framework that the Directorate abides by and adheres to in the course of performing CS Assessment and Security Engineering missions.

3.0 HOW TO USE THIS MANUAL

Throughout this manual, there are footnotes and other references that will identify additional documents, checklists, forms, Worldwide Web (WWW) addresses, policies and procedures, and should be used to enhance the understanding the reader can gain from this manual to successfully complete the Directorate's mission.

This manual is distributed with a supporting file structure that contains other documents, templates, Standard Operating Procedures (SOPs), checklists, forms, etc.. Please see Appendix B for details.





When a footnote or reference refers to a document, it will depict the structure shown on the Directorate's SharePoint portal. However, all documents are also contained within the Data Collection and Archive Folder Structure (DCAFS) under "References and Tools," as well as part of the Information Assurance (IA) Security Evaluation Laptop (ISEL) WIKI.

4.0 HOW THIS MANUAL IS UPDATED

To ensure that all Directorate personnel have the most up-to-date and most efficient methods, this manual will be updated as needs arise. This manual is posted on the Directorate's SharePoint portal¹ and distributed as part of the DCAFS².

It is the responsibility of all Directorate personnel to ensure they are operating under the guidance of the most recent revision of this manual. Changes, additions, or modifications will be identified in the Version Control and Change Log³.

Directorate personnel can propose changes to any process or procedure (operational or technical) referenced in this manual or any other manual, process document, or guide. To propose any change, please process those request through the appropriate chain of command. Directorate leadership supports all input concerning operational efficiency, technical accuracy, and product improvements.

5.0 MISSION

The mission of the Directorate is to provide the Army with a full service CS Assessment and Security Engineering support capability to ensure that Army Information Systems (IS), networks, and infrastructures are properly secured, assessed, and authorized to meet the Army's sustaining base and force protection CS needs. The Directorate is the Army's premier CS Assessment and Security Engineering service provider.

6.0 CS

6.1 CS is a Process, not a Discrete Event

At the project development level, the CS Process has two components:

- Security Engineering Process - That sub-discipline of Systems Engineering (SE) responsible for the identification and integration of security requirements and satisfaction of those requirements, in an interdisciplinary manner throughout the life cycle of an IS.
- Assess and Authorize Process - The Validation and Verification (V&V) of CS requirements, the resultant risks identification to the system and the enterprise, and the acceptance or rejection of that risk.

Both processes must address system development, system fielding, system operation, security sustainment, and End of Life (EOL) cycle security needs.

¹ <https://cecom.aep.army.mil/cecom/ISEC/MED>

² See Section 14.2 of this manual

³ Table 3, page 1





7.0 TERMS AND ACRONYMS

The title of the individual managing the systems the Directorate evaluates can be Program Manager (PM), System Owner, Commander, Director, etc. To aid readability, this manual will refer to this individual as the Customer.

Directorate support can consist of a site, enclave, network, system, application, or all of the above. As indicated above, the term Customer will identify WHOM, this manual will use the term System to identify WHAT. See Glossary for common acronyms.

8.0 REFERENCES

CS References are listed in Appendix A.

9.0 SCOPING, PROJECT INITIATION, AND FUNCTIONAL SUPPORT AGREEMENT (FSA) DEVELOPMENT

The Directorate has several project initiation processes:

- Security Control Assessor (SCA)-Validator (SCA-V) efforts for the SCA-Army (SCA-A)
- CS efforts for other organizations (e.g., Medical Command (MEDCOM))
- Security Engineering and other CS support efforts

SCA-V assessments in support of the SCA-A are initiated in and/or routed through the Army Enterprise Mission Assurance Support Service (eMASS⁴), which is under the control of the CS Division (CSD), U.S. Army Network Enterprise Technology Command (NETCOM). Because all SCA-V work is processed through eMASS and under the auspices of the SCA-A, all SCA-V work must follow a predefined business process controlled by the CSD, NETCOM. This process is conducted outside of and in addition to, the standard Command's guidance as outlined in the NETCOM-provided Tactics Techniques and Procedures (TTP) documentation, which can be found on the Risk Management Framework (RMF) Knowledge Service (RMF KS) under RMF Knowledge Service⁵ > Collaboration > Component Workspaces > US Army Component Workspace > US Army Component Workspace - Operations. The detailed process for scoping SCA-V efforts is referenced in the SCA-V - Support Operations Manual⁶

Efforts in support of other component Assessment Authorities and efforts where the Directorate is acting as the SCA, adhere to the process defined by the SCA of that component. The Directorate GLs or Senior Project Leads (SPLs) are the initial Points of Contact (POCs).

Directorate personnel or Project Leads (PLs) route all Security Engineering and other CS support requests for service from new Customers to one of the GLs or SPLs. At the direction of a GL, the SPL manages Security Engineering and other CS support request from existing Customers.

⁴ <https://emass-army.csd.disa.mil> Email Certificate Required for Authentication

⁵ <https://rmfks.osd.mil/rmf> Email Certificate Required for Authentication

⁶ Cybersecurity Manuals & Supporting Documents \00_Policy-Process-SOP-TTP \SCA-V Support – Operations Manual





The Directorate's process for Project Initiation and FSA development for non-SCA-V efforts adheres to the Command's guidance. For SCA-V efforts, the FSA creation process will adhere to Command templates and standards; however, the timeline associated with SCA-V efforts must follow the requirements of the CS Division, NETCOM (these timelines are documented in the NETCOM TTPs located on the RMF KS website).

10.0 CS SERVICES

This section identifies the services provided to our Customers and the final deliverable of each service. All final deliverables (both USG and contract) must be completed in eMASS and reviewed by the designated Approving Official (AO). The designated AO digitally signs all final memorandums and deliverables going to an outside organization. All draft memorandums and deliverables sent to an outside organization will be clearly marked DRAFT.

10.1 Matrix Support

The Directorate provides CS support to other Command Directorates, where the Directorate is acting as an extension of another Command Directorate. The Directorate will usually not have an FSA, but rather the services provided by the Directorate will be requirements-based. The Directorate can provide any of the services listed herein or additional CS services, as required, by the project and requested by the owning Directorate.

10.2 Initial Scoping

In some cases, the full scope of a mission cannot be determined without a visit to the location where the environment exists. An initial assessment is performed to evaluate the system or environment, determine the scope of work, and roughly assess the security posture of the system. This is usually a short, 2- or 3-day visit where assessment of personnel, processes, documentation, facility, and technical settings occur to fully evaluate the complexity of the mission. The final level of work and costs can then be negotiated with the Customer.

Because the purpose of this type of effort is to complete scoping of the project, the assessment report should provide as much detail as possible about the system's mission, architecture/data flows, scope, environment, processes, and systematic problems likely to impact authorization or the security of the system. Presumably, the customer will accept the final FSA estimate and an assessment report will be provided based on the agreed upon timeline.

10.3 Security Assessment (SA)

An SA is a focused assessment of a specific component or system. During the assessment, Directorate personnel will collect technical and non-technical data associated with the focus area. The purpose of the assessment is to identify areas that are not in compliance with regulations and/or configuration guidance in order to address the overall security posture of the focus area. Additionally, as required by the Customer, a "get-well" plan should be included as part of the recommendation. If the assessment is to verify implementation of a type accreditation, the report should address if the system was installed In Accordance With (IAW) the authorization decision (e.g., RMF Authority To Operate (ATO)).





The deliverable to the Customer is a Security Assessment Report (SAR) signed by the GL. A template for the SAR is available in this manual's supporting file structure and will be used to create the report.⁷

10.4 Preliminary Assessment

A Preliminary Assessment could be a full- or partial-assessment of the Customer's system or environment. Directorate personnel will assess the security posture of the system using the same techniques and practices that are used in an official RMF Assessment. The CSD will be releasing specific information regarding how to conduct a Preliminary Assessment to ensure continuity amongst all SCA-V; however, it is not available at the time of this release of the CS Assessment and Security Engineering Manual.

The deliverable to the customer is a Compliance Report Spreadsheet and a Preliminary Assessment Memorandum signed by the SPL or GL. The Preliminary Assessment Memorandum template is available on the Directorate's SharePoint portal⁸.

10.5 Assessment

An Assessment is a Test and Evaluation (T&E). These are the test events required before the system's operational status is determined. During an assessment, Directorate personnel evaluate the system for overall Security Control compliance in support of the SCA-V. Even though the customer pays for the assessment, the Assessment Team is working for the SCA-A. The T&E is an in-depth assessment that addresses all RMF control families, including all applicable overlays for the system being evaluated. The SCA-V is charged with determining the overall security posture of the system by validating compliance with Department of Defense (DoD) Instruction (DoDI) 8510.01, DoDI 8500.01, National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, Committee on National Security Systems Instruction (CNSSI) 1253, and any other requirements for assessment. In addition, the SCA-V Team is required to follow all assessment procedures, as outlined in the SCA-V TTP (and any other applicable TTPs and Fragmentary Orders (FRAGOs)) found on the RMF KS⁹

The deliverable to the SCA-A (NETCOM CSD) is an SCA-V Recommendation Memorandum, signed by the SCA-V. If applicable, this memorandum includes an enclosure for conflicting inherited controls. The Recommendation Memorandum is uploaded by the SCA-V to the Artifacts section of eMASS. Templates for the SCA-V Recommendation Memorandum and Enclosure are available on the Directorate's SharePoint portal¹⁰.

⁷ Cybersecurity Manuals & Supporting Docs 03_Memo_Templates \ Security_Assessment_Report_Template

⁸ Cybersecurity Manuals & Supporting Docs \ 03_Memo_Templates \ Preliminary_Assessment_Memo_Template

⁹ <https://rmfks.osd.mil> [RMF Knowledge Service](#) > [Collaboration](#) > [Component Workspaces](#) > [US Army Component Workspace](#) > [US Army Component Workspace - Operations](#)

¹⁰ Cybersecurity Manuals & Supporting Docs \03_Memo_Templates\





The SCA-V also creates a SAR from eMASS and uploads a copy into the Artifacts section of eMASS, once all controls have been processed and the Recommendation Memo has been signed.

11.0 PROCESSES

11.1 Security Engineering Process

Security Engineering is a sub-discipline of SE responsible for the identification and integration of security requirements and satisfaction of those requirements in an interdisciplinary manner, throughout the life cycle of an IS. This includes the technical, procedural, and documentation work that is required to prepare a system for assessment under RMF. Security Engineering is intended to ensure that systems of any size or complexity meet all applicable CS requirements and are designed, implemented, and maintained in a manner that complies with all DoD, Army, and other policies. The ultimate goal is a secure, sustainable, assessed, and authorized system that protects itself from external threats, and protects the DoD Information Network (DoDIN) from any internal or external threats. See Appendix C for more information on the Security Engineering Process.

11.2 Assessment Process

An assessment is the comprehensive evaluation of the technical and non technical security features of a system and other safeguards made in support of the authorization process, to establish the extent to which a particular design and implementation meets a set of specified security requirements. An assessment primarily addresses software, hardware, firmware, and data security measures. It must also consider procedural, physical, personnel, threat, and emissions security.

The MED SCA-V is one of the Army's CSD, NETCOM-appointed SCA-Vs under the Army's single SCA model. As an SCA-V, the Directorate acts as an objective third party and independent validator. The Directorate provides a complete and detailed analysis of the level of compliance with DoD and other requirements, and the risk associated with operating the system. With this analysis from the SCA-V, the SCA-A is able to make an informed decision to determine a systems operational status. This analysis also assists the AO in determining whether or not to accept the risk associated with any findings in the analysis. The Assessment Team must follow all guidance as published in the various TTPs (Especially the SCA-V TTP) and FRAGOs approved by the NETCOM CSD. These documents are continually updated and can be downloaded from the RMF KS.¹¹ See Appendix C for more information on the Assessment Process.

Approval to deviate from any documented process can be obtained through discussions with the SPL, the GL, or the SCA-V Lead.

¹¹<https://rmfks.osd.mil/rmf/collaboration/Component%20Workspaces/USArmyCW/USArmyOperations/RMF%20Operations%20Document%20Library/TTPs>





12.0 TRAINING AND CERTIFICATION

12.1 IA Training Facility

The Directorate maintains a training facility and lab environment for use by all Directorate personnel. The IA Training Facility (ITF) personnel maintain the ISEL according to Directorate processes and procedures.

The ITF maintains test environments where the tools used by the Directorate can be tested prior to use in a Customers environment, and where training can occur.

12.2 Sustainment Training

The Directorate provides sustainment training based on the training needs of Directorate personnel. Training subject areas, schedules, and audience will be at the direction of Directorate leadership. Senior Directorate personnel may be called on to provide subject area training, as required. The Subject Matter Expert (SME) staff will oversee sustainment training, as well as provided training.

12.3 Certification

IAW DoD Directive (DoDD) 8140.01 and DoDI 8570.01-M, all cyberspace workforce personnel must become compliant with the mandated Information Technology (IT) and Security certification standards within a certain time frame.

All PLs and SPLs will be appointed as IA System Architects and Engineers Level 2 (IASAE II), and will maintain their certification for that standard

Any Team Leads or Team Members will be appointed as IA Technical Level 2 (IAT II) and will maintain their certification for that standard

Any interns that are assigned to the U.S. Army Information Systems Engineering Command (USAISEC) MED and are not part of the cyberspace workforce, for example, pathway interns are categorized as “general” and do not have to obtain any certification standard.

13.0 DATA COLLECTION, ANALYSIS, AND RETENTION

13.1 Data Collection

The Directorate collects data to scope the project, to understand the system being evaluated, to determine compliance with security controls, and to understand any mitigating and/or aggravating factors. The data collected can be in the form of system documentation, interview questions and answers, vulnerability scan data, notes based on observations, and evidence of compliance/non-compliance. All data collected is maintained and archived using the DCAFS, see section 13.6.

13.2 Protecting Raw Data

The data and documentation collected during an assessment carries the identified classification of the assessed system and the Directorate has a responsibility to protect this information accordingly. Prior to collecting and/or storing data or documentation, ensure that the Classification Guide applicable to the system or environment is obtained and reviewed. Ensure proper protection mechanisms are in place and all applicable procedures, regulations, and/or policies are followed concerning the classification of the data collected.





13.3 Collecting and Validating Technical Data

While onsite the Directorate personnel will verify all Security Technical Implementation Guide (STIG) requirements when 1) evaluating a small number of systems or devices, OR 2) when there is sufficient time for large systems. The minimum acceptable performance when evaluating STIG requirements is to validate every open finding (ALL severity categories), as well as all non-reviewed Category (CAT) I and as many non-reviewed CAT II STIG checks as time allows. Directorate personnel must consider which STIGs apply to the system and how to validate those STIG requirements. Directorate personnel collect technical raw data as validation evidence, which is later analyzed to determine compliance and security posture. The Directorate has various tools at its disposal to facilitate both manual and automated data collection and validation. While the tools available cover many of the technical requirements, no single tool covers all of them; therefore, Directorate personnel should ensure they use any available mechanisms to collect and validate data. Additionally, the operational environment of a device must be considered and evaluated to ensure there are no operational deficiencies that aggravate a potential vulnerability, due to technical configuration. The bottom line is, you must know what technical guides or references (i.e., STIGs) apply, the validation of an automated tool, and which manual checks must be performed. If the evaluation is a one-off type of equipment and there is no DoD regulation or guide, due diligence requires evaluating compliance with any vendor-published or industry standard guidelines. Checklists must be created from each STIG using Security Content Automation Profile (SCAP) Compliance Checker (SCC) and saved as Continuous Monitoring and Risk Scoring (CMRS) Extensible Markup Language (XML) file format and uploaded into Asset Manager within eMASS. In addition, Assured Compliance Assessment Solution (ACAS) scan reports are created as pairs, Advanced Recording File (ARF) and Action Script Remote (ASR) format, and must be uploaded to Asset Manager as well.

13.4 Sampling

When collecting data from large systems, it would be virtually impossible to test every device in the time allocated for the Security Engineering or Assessment effort. Compliance with technical Security controls can be determined by sampling a number of “like” devices. Directorate personnel use a standard sampling rate to assess compliance. To qualify as “like” devices; the equipment must be of the same baseline, perform the same function, exist in the same operational environment, and be administered by the same personnel. For example, the Human Resources Department is using Dell Laptops, which are administered by the Human Resources Workstation Team. These devices are “like” devices. All Exchange 2007 servers running on Windows Server 2003 with the same baseline, administered by the Network Enterprise Center (NEC) Exchange team are “like” machines. Use extreme caution when attempting to sample network devices. It’s important they are also at the same layer in the architecture and perform the same security functions. A perimeter router is not the same as an End User Building (EUB) router, even if the Operating System (OS) and administrators are the same.





Table 4. Sampling Example

Like Systems	Sample Rate		Like Systems	Sample Rate
1-3	Test All		4-25	Test 3
26-50	Test 5		51-90	Test 6
91-150	Test 7		151-280	Test 10
281-500	Test 11		501-1200	Test 15
1201-3200	Test 18		3201-10000	Test 22

13.5 Data Analysis

All scan data must be analyzed. Scan data may be analyzed using Vulnerator, a spreadsheet, or any other capability as long the team can show that analysis was performed. This analysis documentation must be uploaded to the Artifacts section of eMASS using the required nomenclature “SCA-V_[SysAcr]_[Doctype].[xyz]”. This nomenclature must be used for ALL artifacts uploaded to eMASS by the SCA-V team. For a complete list of approved nomenclature for artifacts, please reference the SCA-V TTP.

The Risk Calculator Excel Spreadsheet, found on the Directorates SharePoint¹² site must also be completed and uploaded to the Artifacts section of eMASS. The Risk Calculator must be completed and used to identify the highest watermark of likelihood and impact within the non-compliant controls for the system’s overall risk (placed in the risk matrix portion of the recommendation memorandum), as well as the values for Vulnerability Severity Value and Control Risk Value in eMASS under the “Risk Assessment Summary” tab.

All scans completed by the Assessment Team must be zipped and uploaded to the Artifacts section of eMASS. All test results for each applicable Common Communication Interface (CCI) must be completed within eMASS by the Assessor starting from the beginning of the assessment period (30-working days prior to the onsite visit) to completion. Further information on Data Analysis can be found in the Data Analysis SOP, located on the Directorate’s SharePoint portal¹³.

13.6 Data Retention

Data collected and analyzed during a mission becomes part of the Directorate archives. The central repository is a combination of SharePoint and a Storage Area Network (SAN), in which a copy of all mission data is archived. The Directorate does not maintain data past 3 years Plus (+) 3 months. The reasoning for the Directorate’s retention period is that RMF ATO decisions do not exceed 3 years. The Directorate allows for an additional 3 months beyond the 3-year ATO.

¹²Cybersecurity Manuals & Supporting Docs \00_Policy-Process-SOP-TTP\Risk Assessment Calculation Information\RiskCalculatorRMF

¹³Cybersecurity Manuals & Supporting Docs \00_Policy-Process-SOP-TTP\SOP Data Analysis





14.0 TOOLS

The Directorate has many tools available for various aspects of our services. The Directorate developed some of these tools specifically for our functions and others are Commercial-Off-The-Shelf (COTS). See the ISEL Accreditation Package for a complete listing of tools and software available. The sections below identify the Directorate's three primary tools.

14.1 ISEL - Pronounced I-SELL

The ISEL is a Road Warrior system as defined in the Road Warrior Best Business Practice (BBP)¹⁴. The ISEL image is configured from a master image maintained by the ITF. Directorate personnel use the ISEL to scan Customer environments for configuration and vulnerabilities, and to collect and maintain all data collected during the course of an assessment; it does not connect to any other network outside the scope of the Customer's system boundary, in which Directorate personnel have been engaged to operate. Directorate personnel may do some administrative work using the ISEL, such as writing control notes or analyzing data. Upon return to home station, the collected data from the Customer's system and other documents developed during the deployment are transferred from the ISEL to archive media using the DCAFS, and the ISEL is turned in to the ITF personnel for re-imaging with the most current image.

Note that if the ISEL becomes Classified during the deployment, the ISEL will be wiped securely IAW current DoD and U.S. Army policies before it may be re-imaged and re-issued. The data recovered will be handled and stored IAW Army Regulation (AR) 380-5, Department of the Army Information Security Program; the relevant Security Classification Guide; and other DoD and Department of the Army (DA) guidance, as applicable. See the Directorate's SharePoint portal for more details on the ISEL.¹⁵

DCAFS is designed for "cradle to grave" use throughout an effort. Using the file structure from the beginning of the effort will support the organization of data efficiently and in the structure needed for the final archive. Many references or tools needed during system familiarization, the onsite effort, or post deployment analysis are readily available within the 99_References_and_Tools folder.

DCAFS is jointly maintained by the Directorate's CS Assessment, Security Engineering, and Application SMEs. Additional information on DCAFS is available on the Directorate's SharePoint portal¹⁶.

14.2 ISEL WIKI

The WIKI is located on the Directorate's ISEL image. The WIKI includes all data previously stored in the References and Tools folder of DCAFS. This includes all information regarding use and training of various tools used by Directorate personnel during a security engineering effort or an assessment.

14 Army BBP 06-EC-O-0007, Road Warrior Laptop Security

15 <https://cecom.aep.army.mil/cecom/ISEC/MED/Lists/iselrllup/AllItems.aspx>

16 <https://cecom.aep.army.mil/cecom/ISEC/MED/Lists/dcafsrllup/AllItems.aspx>





Directorate personnel are expected to access the WIKI for guidelines to appropriately configure and use all tools necessary.

DCAFS is maintained by the Directorate's Application SME. The WIKI is updated on an as-needed basis. Updates to the WIKI coincide with updates to tools and applications used by the Directorate, as well as when new training on tools becomes available.





This page intentionally left blank.





APPENDIX A. REFERENCES

A-1.0 USG REFERENCES

- a. DoD, DoDD 8500.01, Cybersecurity, March 2014.
- b. DoD, DoDI 8510.01, Risk Management Framework (RMF) for DoD Information Technology (IT), May 2016.
- c. Headquarters (HQ), Department of the Army (HQDA), AR 25-1, Army Knowledge Management and Information Technology, December 2008.
- d. HQDA, AR 25-2, Information Assurance, October 2007.

A-2.0 NON-USG REFERENCES

- a. Defense Acquisition University (DAU), BBP 06-DC-M, Army Best Business Practice - Assessment & Accreditation, November 2006.
- b. DAU, BBP 06-DC-M-004, Army Best Business Practice - Assessment Authority, November 2006.
- c. DAU, BBP DC-M-006, Army Best Business Practice - Agent of the Assessment Authority (ACA), November 2006.
- d. NIST, SP 800-30, Guide for Conducting Risk Assessments, September 2012.
- e. NIST, SP 800-37, Guide for Applying the Risk Management Framework to Federal Information Systems, 10 June 2014.
- f. NIST, SP 800-53, Security and Privacy Controls for Federal Information Systems and Organizations, 22 January 2015.
- g. NIST, SP 800-53A, Assessing Security and Privacy Controls in Federal Information Systems and Organizations, 18 December 2014.





This page intentionally left blank.

A-2

FOR OFFICIAL USE ONLY





APPENDIX B. SUPPORTING FILES (FILE STRUCTURE)

B-1.0

The Directorate maintains supporting documents in the folder structure that accompanies this manual. Below is an overview of what is contained in each folder. The contents of the supporting file structure will change on a regular basis; therefore, the current copy should be reviewed prior to initiating work on behalf of the Directorate.

B-1.1

00_Policy-Process-SOP-TTP. This folder contains documentation that pertains to processes, SOPs, TTPs, and policy. Examples of the types of documents contained here are:

- SCA-V Support - Operations Manual
- Security Engineering Process
- NETCOM TTPs
- Risk Assessment Calculation Information

B-1.2

01_Briefing_Templates. This folder contains templates to be used for creating briefs. Examples of the types of templates contained here are:

- In Brief Template
- Out Brief Template

B-1.3

02_Checklists. This folder contains checklists will aid in ensuring Directorate policies and procedures are followed. Examples of the types of checklists contained here are:

- Deliverable Staffing Checklist
- Post-Deployment Checklist
- Pre-Deployment Checklist
- Test Readiness Review (TRR) Checklist
- Self-Assessment Validation Review (SAVR) Checklist

B-1.4

03_Memo_Templates. This folder contains templates to be used when creating Memorandums and Enclosures that are addressed to an outside entity or agency. These templates have been created IAW AR 25-50.

B-1.5

04_Other_Templates. This folder contains the RMF SCA Test Plan and evaluation forms that are provided to our Customers so they can provide feedback to Directorate management.





This page intentionally left blank

B-2

FOR OFFICIAL USE ONLY





APPENDIX C. PROCESSES

The Security Engineering Process was developed by the Security Engineering SME to describe security engineering in detail. For ease of use by Directorate personnel, this separate document is provided as part of this manual's supporting file structure. The Security Engineering Process is maintained in the Policy-Process-SOP-TTP folder of the Directorate's SharePoint site.

The Assessment and Authorization Process used to support the SCA-V was developed by the Assessment SME. For ease of use by Directorate personnel, this separate document is provided as part of this manual's supporting file structure. The SCA-V Support - Operations Manual is maintained in the 00_Policy-Process-SOP-TTP folder of the Directorate's SharePoint site.





This page intentionally left blank.

C-2

FOR OFFICIAL USE ONLY





GLOSSARY. ACRONYMS AND ABBREVIATIONS

+	Plus
ACA	Agent of the Assessment Authority
ACAS	Assured Compliance Assessment Solution
AO	Authorizing Official
AR	Army Regulation
ARF	Advanced Recording File
ASR	
ATO	Authority To Operate
BBP	Best Business Practice
CAT	Category
CCI	Common Communication Interface
CDRL	Contract Data Requirements List
CMRS	Continuous Monitoring and Risk Scoring
CNSSI	Committee on National Security Systems Instruction
COTS	Commercial-Off-The-Shelf
CS	Cybersecurity
CSD	CS Division
DA	Department of the Army
DAU	Defense Acquisition University
DCAFS	Data Collection and Archive Folder Structure
DoD	Department of Defense
DoDD	Department of Defense Directive
DoDI	Department of Defense Instruction
DoDIN	Department of Defense Information Network
eMASS	Enterprise Mission Assurance Support Service
EOL	End of Life
EUB	End User Building
FRAGO	Fragmentary Order
FSA	Functional Support Agreement
GL	Group Leader
HQ	Headquarters
HQDA	Headquarters, Department of the Army
IA	Information Assurance

Glossary-1

FOR OFFICIAL USE ONLY





IASAE II	IA System Architects and Engineers Level 2
IAT II	IA Technical Level 2
IAW	In Accordance With
IS	Information System
ISEL	IA Security Evaluation Laptop
IT	Information Technology
ITF	IA Training Facility
KS	Knowledge Service
MED	Mission Engineering Directorate
MEDCOM	Medical Command
NEC	Network Enterprise Center
NETCOM	U.S. Army Network Enterprise Technology Command
NIST	National Institute of Standards and Technology
OS	Operating System
PL	Project Lead
PM	Program Manager
POC	Point of Contact
RMF	Risk Management Framework
SA	Security Assessment
SAN	Storage Area Network
SAR	Security Assessment Report
SAVR	Self-Assessment Validation Review
SCA	Security Control Assessor
SCA-A	Security Control Assessor-Army
SCA-V	Security Control Assessor-Validator
SCAP	Security Content Automation Profile
SCC	SCAP Compliance Checker
SE	Systems Engineering
SME	Subject Matter Expert
SOP	Standard Operating Procedure
SP	Special Publication
SPL	Senior Project Lead
STIG	Security Technical Implementation Guide
T&E	Test and Evaluation
TRR	Test Readiness Review
TTP	Techniques and Procedures

Glossary-2

FOR OFFICIAL USE ONLY





USAISEC
USG

U.S. Army Information Systems Engineering Command
U.S. Government

V&V

Validation and Verification

WWW

Worldwide Web

XML

Extensible Markup Language





This page intentionally left blank.

Glossary-4

FOR OFFICIAL USE ONLY

